

Enterprise Cybersecurity



Nancy LaTourrette
Computer Science & Engineering

Enterprise Cybersecurity

"Amateurs hack systems, professionals hack people."

-- Bruce Schneier, Cryptographer  social engineering

"The speed with which organizations are adopting cloud is ahead of their ability to secure that usage."

-- Doug Cahill, Senior Analyst, The Enterprise Strategy Group

 → analogous to the first computer networks, minor systems among academics

Enterprise Vulnerabilities

Cybersecurity vulnerabilities are weaknesses in an organization's cyber defenses that leaves them vulnerable to a cyber threat or attack. Those vulnerabilities can lead to crime of opportunities.

Human Error – misconfigured systems or unpatched systems accounted for 25% of data breaches in the U.S.¹

Cloud Security – organizations rely on cloud providers for security but some cloud services defer a level of security to the organization.

IoT Devices – vulnerabilities in IoT devices have doubled since 2013³, compromising enterprise networks.

Social Engineering – enterprise employees are particularly susceptible to social engineering attacks.

(Enterprise) Social Engineering

Social Engineering is the use of deception and psychology to manipulate individuals into divulging confidential information that may be used for fraudulent purposes.

Phishing – most common type of social engineering attack, uses email or social media as an attack vector with the goal of the user revealing confidential information by clicking on a malicious link.

Pretexting – attackers create a fabricated scenario to obtain confidential information or access to a restricted area.

Baiting – leaving infected memory devices in plain view tempting the victim to pick it up and mount on a computer.

Shoulder Surfing – attempts to obtain personal information, usually logon credentials, by looking over the user's shoulder and recording the information.

Piggy Backing – also known as tailgating, attacker without the proper authorization follows an authenticated user into a restricted area.

Insider Threats¹

An insider threat is a person who has or had authorized access to an organization's network, system, or data and intentionally misused that access.²

Disgruntled Employees – dissatisfied employees who **take revenge** on an enterprise due to lack of promotion or poor relations with managers and/or co-workers. Usually an emotional response.

Malicious Insiders – employees who **abuse their access** to steal, leak or delete enterprise data out of malicious intent.

Inside Agents – corporate spies inside the organization whose aim is to **steal proprietary information** for financial gain.

Regular Employees – **inadvertently leak data** either by mistake or through social engineering.

Third-Party Providers and Contractors – malicious parties who compromise data through legitimate **full or partial access**.

Standards, Guidelines, Procedures

Security Policies - directives, regulations, rules, and practices that prescribes how an organization manages, protects, and distributes data.

Example: Acceptable Use Policy.

Organizational Standards - specify uniform use of specific technologies, parameters, or procedures when such uniform use will benefit an organization. Usually compulsory within the organization.

Example: Identification Badges required on site.

Guidelines - a collection of system specific or procedural specific "suggestions" for best practice. They are not requirements to be met, but are strongly recommended.

Example: Employ a password manager.

Procedures - detailed steps to accomplish a task and thereby describing how to implement applicable security policies, standards, and guidelines.

Example: How to apply for elevated privileges.

Examples of Issue-Specific Policies

whitelist
Internet Access - includes identifying who will have access, what systems may be connected to the network, types of information that may be transmitted, requirements for user authentication **for Internet-connected systems**, and the use of firewalls. *opening specific ports, WPA3-Enterprise*

Email Privacy - clarifies what information is collected and stored and the way the information is being used. Addresses what **level of privacy to expect** as well as the circumstances under which email may be read.

Bring Your Own Device (BYOD) - allows individuals to **use personal devices in the workplace**. *unaccounted for vulnerabilities* Introducing user configurations to the organizations network can be challenging; security of the organizations information at risk; the privacy of the employee may be vulnerable.

Social Media - the policy can be strict—not allowing the use of private **social media access on organization provided resources**—or a lenient policy that allows social media access within organization specified limitations. *may be blocked, may host on-prem social media for internal use*

Physical & Environmental Security

ISO 27001 Annex A.11 addresses physical security controls to prevent unauthorized physical access, damage and interference to data and data processing facilities.

Physical Security Perimeter – defined as any transition boundary between two areas of **differing security protection requirements**.

Physical Entry Controls - secure areas need to be protected by the appropriate entry controls to ensure **only authorized personnel are allowed access**. *ID/biometric scans*

Protecting against External & Environmental Threats - identifying, assessing, mitigating or tolerating **potential threats and vulnerabilities (naturally-occurring and man-made) and environmental risks**. *theft, natural disasters*

Access Controls - should **detect during** and after an attack such as CCTVs and alarms and **deter an attack** such as fences, security guards, dogs, and lights.

Cyber Defense Resources & Partnerships

*There are Cyber Defense **resources and partnerships** available to **enterprises** at the local, state, and federal level. These resources range from reporting mechanisms, compliance, security databases, information sharing, and software security to public-private partnerships.*

[Internet Crime Complaint Center \(IC3\)](#) – provides a reporting mechanism to submit information to the FBI concerning suspected Internet-facilitated criminal activity and to develop alliances with law enforcement and industry partners.

[Computer Security Resource Center \(CSRC\)](#) – NIST's Computer Security Division provides access to NIST's cybersecurity and information security related projects, publications, news and events.

[National Cyber Awareness System](#) – offers a variety of information for users with varied technical expertise. Those with more technical interest can read the Alerts, Analysis Reports, Current Activity, or Bulletins.

Cyber Defense Resources & Partnerships

[NIST National Vulnerability Database \(NVD\)](#) - includes databases of security checklist references, security-related software flaws, misconfigurations, product names, and impact metrics.

[Open Web Application Security Project \(OWASP\)](#) – makes software security visible. Operating as a community of professionals, OWASP issues software tools and knowledge-based documentation on application security.

[Malware Information Sharing Project \(MISP\)](#) - large open source project with the goal to make viable tools and format to improve information sharing at large. A community of users and organizations sharing information about threats or cyber security indicators worldwide.

[Cybersecurity and Infrastructure Security Agency \(CISA\)](#)¹ - provides extensive cybersecurity and infrastructure security knowledge and practices to its stakeholders. Part of DHS, CISA has developed and implemented numerous information sharing programs.

Cyber Defense Resources & Partnerships

[Cyber Information Sharing and Collaboration Program \(CISCP\)](#) - enables information exchange and establishment of a community of trust between the Federal Government and critical infrastructure owners and operators.

[National Council of ISACs](#) – Information Sharing and Analysis Centers (ISACs) are non-profit, member-driven organizations formed by critical infrastructure owners and operators to share information between government and industry.

[Research & Education Networks Information Sharing & Analysis Center \(REN-ISAC\)](#) - serves higher education and research community by promoting cybersecurity operational protections and response. Acts as the Computer Security Incident Response Team (CSIRT) for the research and education community.

[Information Sharing and Analysis Organizations \(ISAOs\)](#) - gather, analyze, and disseminate cyber threat information, but unlike ISACs, ISAOs are not sector-affiliated.

Cyber Defense Resources & Partnerships

[Automated Indicator Sharing \(AIS\)](#) - enables the exchange of cyber threat indicators between the federal government, state, local, tribal and territorial governments, and the private sector at machine speed.

[Department of Defense Cyber Crime Center \(DC3\)](#) - delivers forensic services, cyber technical training, vulnerability sharing, technical solutions development, and cyber analysis.

[Homeland Security Information Network \(HSIN\)](#) - system for trusted sharing of sensitive but unclassified information between federal, state, local, territorial, tribal, international and private sector partners.

[InfraGard](#) - provides a vehicle for seamless public-private collaboration with government (FBI) relevant to the protection of critical infrastructure. There are local chapters.

[Nevada Office Of Cyber Defense Coordination \(OCDC\)](#) - serves as the primary focal point for cyber security strategy, policy, planning, and coordination for the State of Nevada.

References

- [1] "AS CLOUD SECURITY IMPROVES, A WEAK LINK EMERGES: PEOPLE", P. GILLIN, SILICONANGLE
<https://siliconangle.com/2019/11/10/cloud-security-improves-weak-link-emerges-people/>

- [2] COMBATING THE INSIDER THREAT, NATIONAL CYBERSECURITY AND COMMUNICATIONS INTEGRATION CENTER, 2014
https://www.uscert.gov/sites/default/files/publications/Combating%20the%20Insider%20Threat_0.pdf

- [3] SANS INFORMATION SECURITY POLICY TEMPLATES
<https://www.sans.org/security-resources/policies>

- [4] NIST INFORMATION SECURITY POLICY GLOSSARY
<https://csrc.nist.gov/glossary/term/information-security-policy>

- [5] NIST SP 800-12 R1, 2017, M. NIELES, K. DEMPSEY, V. PILLITTERI
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-12r1.pdf>

References (cont'd)

[6] ISMS ONLINE, ISO 27001 ANNEX A.11 PHYSICAL & ENVIRONMENTAL SECURITY

<https://www.isms.online/iso-27001/annex-a-11-physical-and-environmental-security/>